

Vulnerability Assessment and Penetration Testing (VAPT) Report

Executive Summary

This report documents the Vulnerability Assessment and Penetration Testing (VAPT) activities performed on a deliberately vulnerable system, Metasploitable 3, in a controlled laboratory environment. The objective of this practical exercise was to identify security weaknesses using open-source tools, assess associated risks, and recommend remediation measures.

The assessment identified multiple high and medium risk vulnerabilities caused mainly by outdated software, exposed network services, and insecure configurations. If exploited in a real-world scenario, these vulnerabilities could lead to unauthorized access, data leakage, and complete system compromise. Immediate remediation is strongly recommended.

1. Introduction

With the rapid growth of information technology and digital infrastructure, organizations are increasingly exposed to cyber threats. Regular security assessments are essential to identify weaknesses before they can be exploited by malicious actors. Vulnerability Assessment and Penetration Testing (VAPT) are widely adopted practices that help organizations evaluate the security posture of their systems and applications.

This report aims to provide both theoretical understanding and practical experience in conducting security assessments using open-source tools. The scope of this study includes understanding security assessment concepts, following a structured VAPT methodology, identifying common vulnerabilities, performing risk assessment, and documenting findings in a professional security report.

2. Theoretical Knowledge

2.1 Understanding Security Assessment

Security assessment is a systematic process of identifying, analyzing, and evaluating vulnerabilities within information systems, networks, and applications. The primary objective of a security assessment is to detect weaknesses that could potentially be exploited and to recommend appropriate mitigation measures. Industry-recognized

frameworks such as the National Institute of Standards and Technology (NIST) provide structured guidelines for conducting effective security assessments.

Security testing can be categorized into multiple types:

- **Vulnerability Assessment:**
This process focuses on identifying known vulnerabilities in systems using automated tools such as OpenVAS. It provides a list of vulnerabilities along with severity ratings but does not involve active exploitation.
- **Penetration Testing:**
Penetration testing simulates real-world cyberattacks to determine whether vulnerabilities can be exploited. Tools available in Kali Linux, such as Metasploit and Nmap, are commonly used for this purpose.
- **Compliance Testing:**
Compliance testing evaluates systems against established standards and best practices, such as CIS Benchmarks, to ensure regulatory and organizational compliance.

2.2 VAPT Methodology

A structured methodology is essential for conducting effective VAPT activities. This assessment follows a standard VAPT lifecycle consisting of four phases:

- **Planning:**
The planning phase involves defining the scope, objectives, and rules of engagement for the assessment. Tools such as Dradis Community Edition (CE) assist in organizing project information and documentation.
- **Discovery:**
During this phase, information about the target system is gathered using reconnaissance and scanning tools. Nmap is used for network scanning, while OWASP ZAP is utilized for web application vulnerability scanning.
- **Attack:**
The attack phase involves exploiting identified vulnerabilities to assess their real-world impact. The Metasploit Framework is commonly used to perform controlled exploitation.
- **Reporting:**
The final phase involves documenting findings, assessing risks, and providing remediation recommendations. Standard reporting templates and formats ensure clarity and professionalism.

To strengthen methodological understanding, the OWASP Web Security Testing Framework (WSTG) is used as a reference for web application security testing.

2.3 Security Standards and Compliance

Security standards and regulatory frameworks play a crucial role in maintaining data confidentiality, integrity, and availability. Commonly recognized standards include:

- **GDPR (General Data Protection Regulation):** Focuses on protecting personal data and privacy.
- **HIPAA (Health Insurance Portability and Accountability Act):** Governs the protection of healthcare information.
- **ISO/IEC 27001:** Defines requirements for establishing an Information Security Management System (ISMS).

The OWASP Top 10 is used as a practical reference to identify and prioritize the most critical web application security risks.

2.4 Risk Assessment Basics

Risk assessment involves evaluating the likelihood and impact of identified vulnerabilities. The Common Vulnerability Scoring System (CVSS) is widely used to assign numerical severity scores to vulnerabilities. The National Vulnerability Database (NVD) CVSS Calculator assists in determining accurate scores.

Additionally, a qualitative risk matrix is used to categorize risks as High, Medium, or Low based on their likelihood and impact. This approach helps organizations prioritize remediation efforts effectively.

2.5 Common Vulnerabilities

Common security vulnerabilities can be broadly categorized into network and web application vulnerabilities:

- **Network Vulnerabilities:**
These include open ports, weak configurations, and exposed services, typically identified using Nmap.
- **Web Application Vulnerabilities:**
Common examples include SQL Injection (SQLi) and Cross-Site Scripting (XSS). These vulnerabilities are practiced and analyzed using intentionally vulnerable platforms such as OWASP Juice Shop.

To gain hands-on experience, vulnerable environments such as Metasploitable and VulnHub virtual machines are utilized.

3. Objective of the Assessment

The objectives of this practical assessment were:

- To set up a secure testing environment using virtual machines
- To perform vulnerability scanning using open-source tools
- To identify and document security vulnerabilities
- To assess risk using CVSS scoring and a risk matrix
- To prepare a comprehensive security assessment report

4. Testing Environment Setup

4.1 Environment Overview

A controlled virtual lab environment was created to safely perform security testing without affecting production systems.

Attacker Machine: Kali Linux

Target Machine: Metasploitable 3

Virtualization Platform: VM Ware

Both virtual machines were configured using a Host-Only Network adapter to ensure isolated communication.

4.2 Environment Configuration Steps

- Kali Linux was installed as the attacker system.
- Metasploitable 3 was downloaded from GitHub and configured as the vulnerable target.
- Vmware was configured to host both virtual machines.
- Network connectivity was verified using ICMP ping tests.

5. Vulnerability Scanning

5.1 Tools Used

- OpenVAS (Greenbone Vulnerability Manager)
- Nikto Web Server Scanner
- Nmap

5.2 OpenVAS Vulnerability Scan

OpenVAS was used to conduct a full vulnerability scan of the target system. The service was initiated using the following command:

```
sudo gvm-start
```

The scan provided detailed results including CVE identifiers, CVSS scores, and severity levels. Several high and medium severity vulnerabilities were detected, primarily due to outdated services and weak configurations.

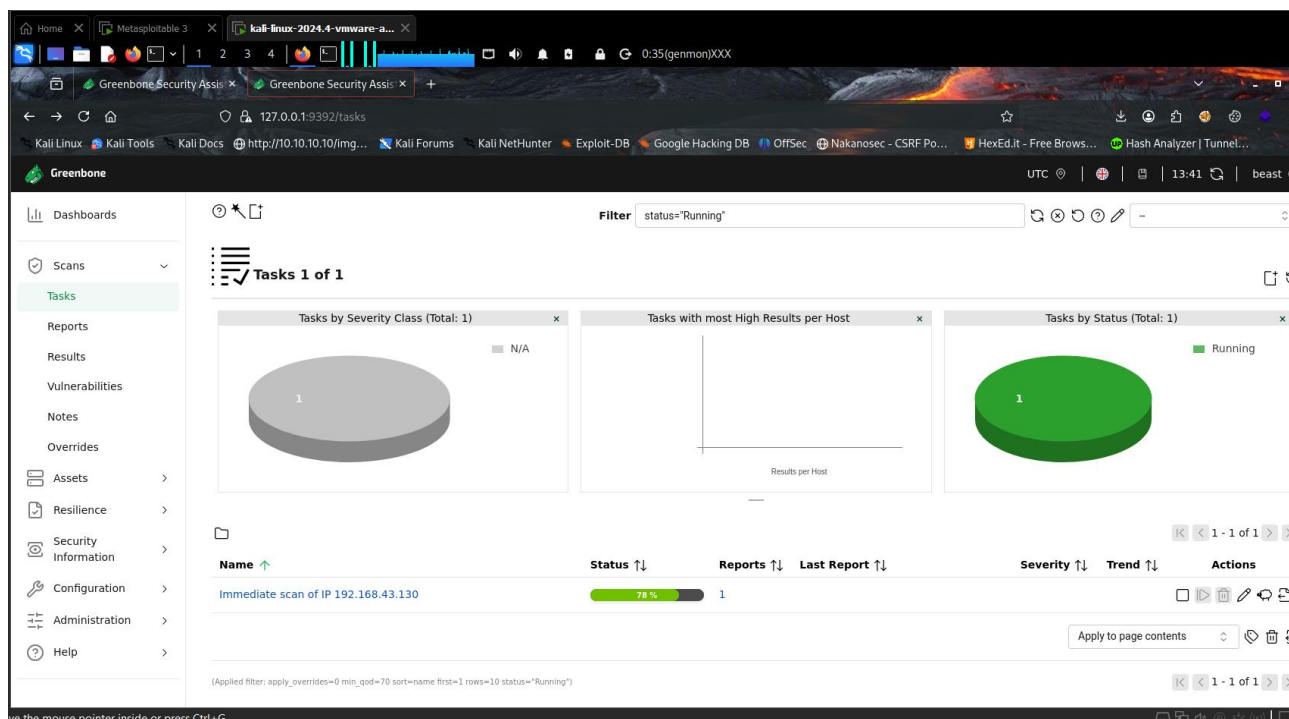
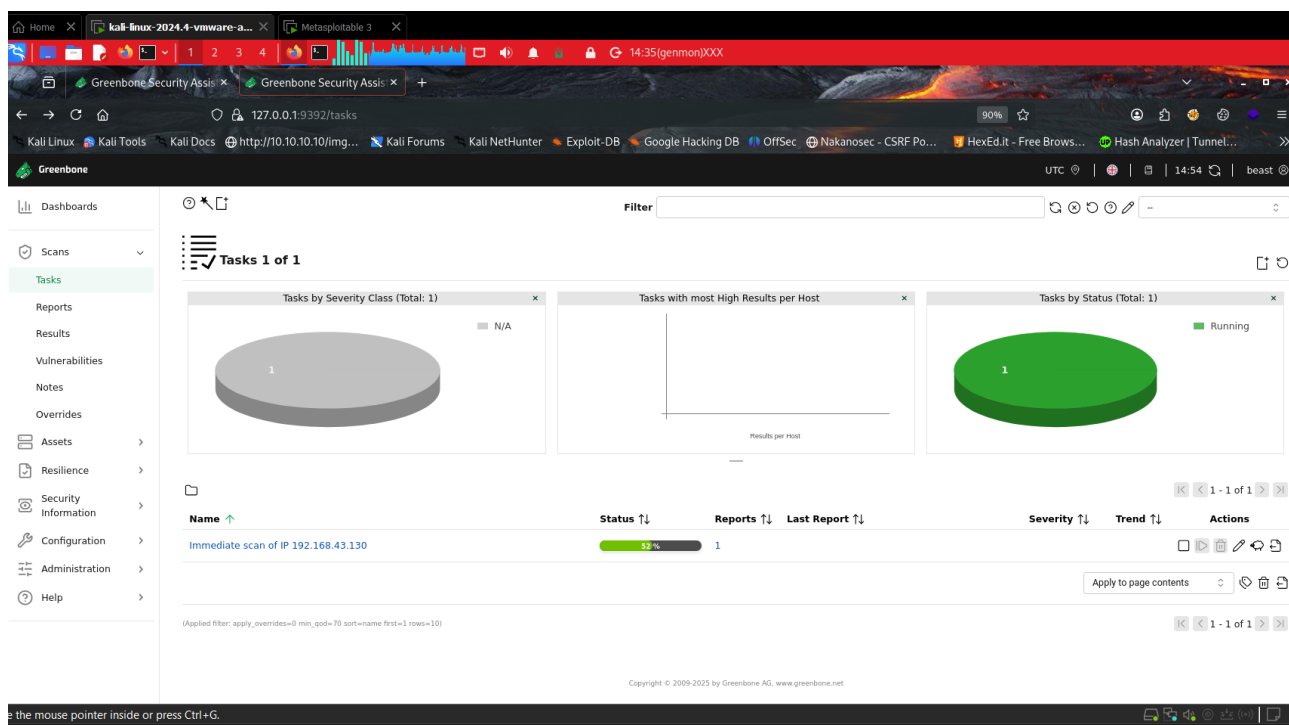
```
(root@kali)~[/home/kali]
# gvm-start
[>] Please wait for the GVM services to start.
[>]
[>] You might need to refresh your browser once it opens.
[>]
[>] Web UI (Greenbone Security Assistant): https://127.0.0.1:9392

● gsad.service - Greenbone Security Assistant daemon (gsad)
   Loaded: loaded (/usr/lib/systemd/system/gsad.service; disabled; preset: disabled)
   Active: active (running) since Wed 2026-01-21 20:47:09 IST; 8ms ago
     Invocation: 7714cd02383c4bcd8f85b6276ffd6526
       Docs: man:gsad(8)
    Security: https://www.greenbone.net
   Main PID: 2686 (gsad)
      Tasks: 1 (limit: 9242)
     Memory: 2.9M (peak: 2.9M)
        CPU: 14ms
    CGroup: /system.slice/gsad.service
            └─2686 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392

Jan 21 20:47:09 kali systemd[1]: Starting gsad.service - Greenbone Security Assistant daemon (gsad)...
Jan 21 20:47:09 kali systemd[1]: Started gsad.service - Greenbone Security Assistant daemon (gsad).
Jan 21 20:47:09 kali gsad[2686]: gsad main:MESSAGE:2026-01-21 15h17.09 utc:2686: Starting GSAD version 24.7.0-git

● gvmd.service - Greenbone Vulnerability Manager daemon (gvmd)
   Loaded: loaded (/usr/lib/systemd/system/gvmd.service; disabled; preset: disabled)
   Active: active (running) since Wed 2026-01-21 20:47:04 IST; 5s ago
     Invocation: 32a54fc7a6494b229f954d1e24a600b7
       Docs: man:gvmd(8)
   Process: 2651 ExecStart=/usr/sbin/gvmd --osp-vt-update=/run/ospd/ospd.sock --listen-group=_gvm (code=exited, status=0/S
   Main PID: 2653 (gvmd)
      Tasks: 1 (limit: 9242)
     Memory: 282.5M (peak: 486.3M)
        CPU: 5.556s
    CGroup: /system.slice/gvmd.service
            └─2653 "gvmd: Waiting " --osp-vt-update=/run/ospd/ospd.sock --listen-group=_gvm

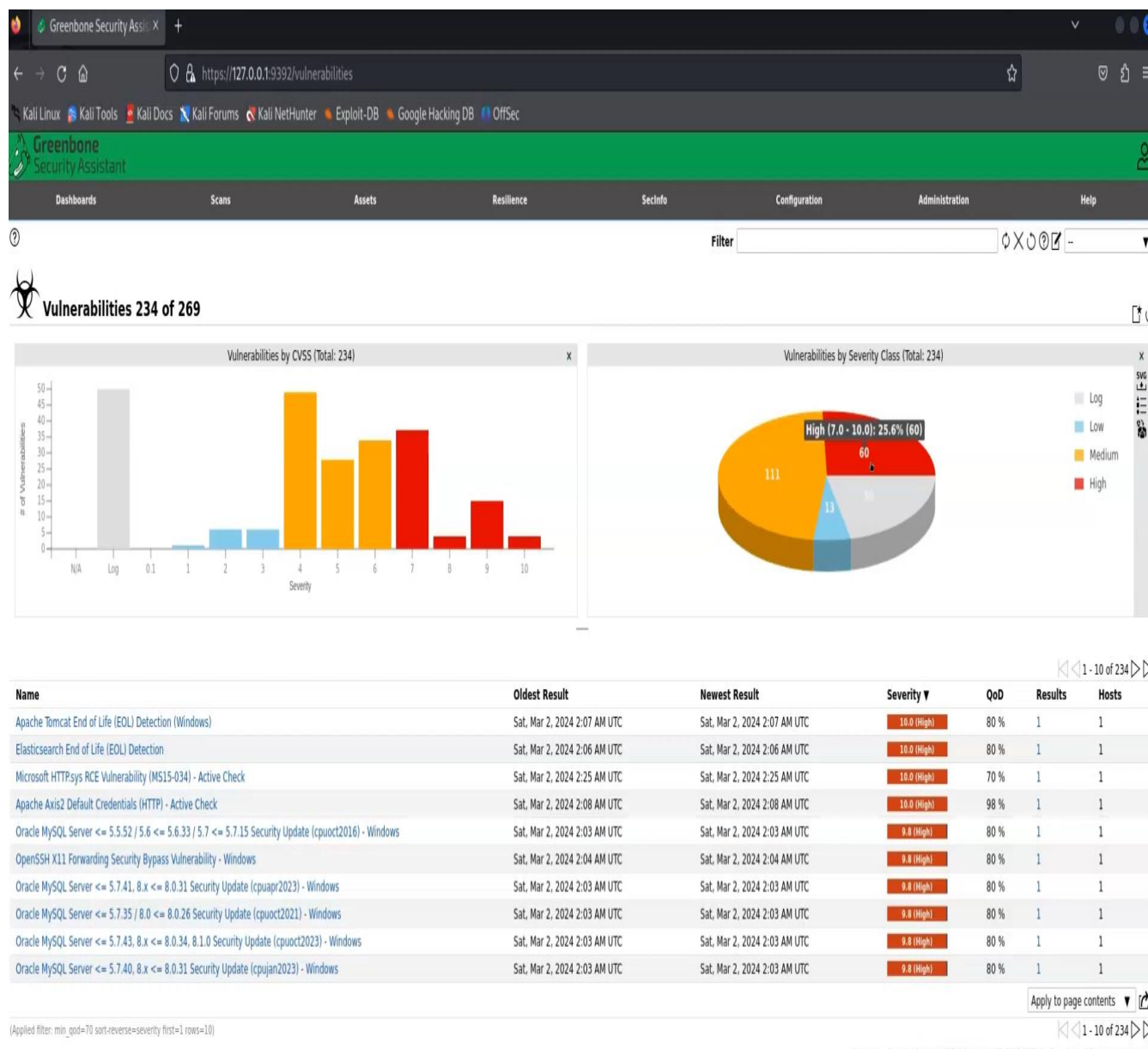
Jan 21 20:47:04 kali gvmd[2653]: HINT: Rebuild all objects in this database that use the default collation and run ALTER
on.
Jan 21 20:47:04 kali gvmd[2673]: WARNING: database "gvmd" has a collation version mismatch
Jan 21 20:47:04 kali gvmd[2673]: DETAIL: The database was created using collation version 2.40, but the operating system
Jan 21 20:47:04 kali gvmd[2673]: HINT: Rebuild all objects in this database that use the default collation and run ALTER
on.
Jan 21 20:47:04 kali gvmd[2675]: WARNING: database "gvmd" has a collation version mismatch
Jan 21 20:47:04 kali gvmd[2675]: DETAIL: The database was created using collation version 2.40, but the operating system
Jan 21 20:47:04 kali gvmd[2675]: HINT: Rebuild all objects in this database that use the default collation and run ALTER
on.
Jan 21 20:47:09 kali gvmd[2687]: WARNING: database "gvmd" has a collation version mismatch
Jan 21 20:47:09 kali gvmd[2687]: DETAIL: The database was created using collation version 2.40, but the operating system
Jan 21 20:47:09 kali gvmd[2687]: HINT: Rebuild all objects in this database that use the default collation and run ALTER
on.
```



This screenshot shows the OpenVAS dashboard displaying scan status, task progress, and overall vulnerability statistics. It provides a high-level overview of the assessment activity.

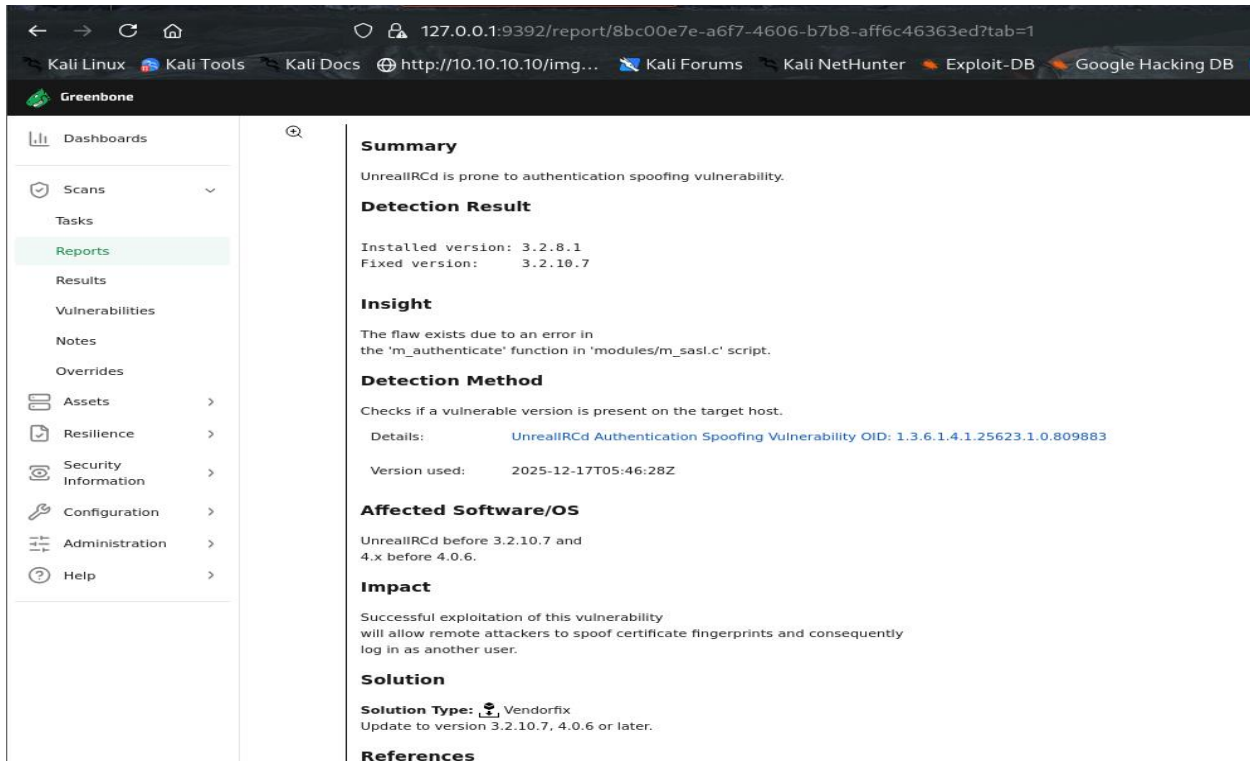


Vulnerability List



This screenshot displays the list of discovered vulnerabilities along with their severity levels (High, Medium, Low), CVSS scores, and associated CVE identifiers. High-severity vulnerabilities are highlighted, indicating critical security risks.

Detailed Vulnerability View



Summary

UnrealIRCd is prone to authentication spoofing vulnerability.

Detection Result

Installed version: 3.2.8.1
Fixed version: 3.2.10.7

Insight

The flaw exists due to an error in the 'm_authenticate' function in 'modules/m_sasl.c' script.

Detection Method

Checks if a vulnerable version is present on the target host.

Details: [UnrealIRCd Authentication Spoofing Vulnerability OID: 1.3.6.1.4.1.25623.1.0.809883](#)

Version used: 2025-12-17T05:46:28Z

Affected Software/OS

UnrealIRCd before 3.2.10.7 and 4.x before 4.0.6.

Impact

Successful exploitation of this vulnerability will allow remote attackers to spoof certificate fingerprints and consequently log in as another user.

Solution

Solution Type: Vendorfix
Update to version 3.2.10.7, 4.0.6 or later.

References

This screenshot provides detailed information about a specific vulnerability, including description, impact, affected services, CVE references, and remediation suggestions. This information is essential for risk analysis and mitigation planning.

5.3 Nikto Web Server Scan

Nikto was used to scan the web server hosted on the target system to identify insecure configurations and outdated components.

The below screenshot shows the Nikto scan results highlighting outdated web server components, missing security headers, and potential security misconfigurations.

```
root@kali: /home/kali
# nikto -h 192.168.43.130
- Nikto v2.5.0

+ Target IP: 192.168.43.130
+ Target Hostname: 192.168.43.130
+ Target Port: 80
+ Start Time: 2026-01-21 20:35:48 (GMT5.5)

+ Server: Apache/2.4.7 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.wisecoders.com/2014/01/21/x-content-type-options-header/
+ /: Directory indexing found.
+ Apache/2.4.7 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
+ /: Directory indexing found.
+ /: Appending '/' to a directory allows indexing.
+ /: Directory indexing found.
+ Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ /2e/: Directory indexing found.
+ /2e/: WebLogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: http://www.securityfocus.com/bid/2513
+ /PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /wp-content: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /phpmyadmin/changelog.php: Retrieved x-powered-by header: PHP/5.4.5.
+ /phpmyadmin/changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /: Directory indexing found.
+ /: Abyss 1.03 reveals directory listing when multiple '/'s are requested. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2006-0911
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpmyadmin/: phpMyAdmin directory found.
+ /phpmyadmin/documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpmyadmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ 8911 requests: 0 error(s) and 22 item(s) reported on remote host
+ End Time: 2026-01-21 20:36:14 (GMT5.5) (26 seconds)

+ 1 host(s) tested
```


5.4 Nmap Scan

```
File Actions Edit View Help
root@kali: /home/kali x root@kali: /home/kali x

(root@kali)~[/home/kali]
# nmap -T4 -p- -A 192.168.43.130
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-21 20:35 IST
Nmap scan report for 192.168.43.130
Host is up (0.0023s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256 c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256 a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http         Apache httpd 2.4.7
|_ http-ls: Volume /
|  SIZE  TIME  Protocol  FILENAME
|  -      -      -          -
|  -      -      -          -
|  1.7K   2020-10-29 19:37  payroll_app.php
|  -      -      -          -
|_  2013-04-08 12:06  phpmyadmin/
|_
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-title: Index of /
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp   open  ipp          CUPS 1.7
|_ http-methods:
|_ Potentially risky methods: PUT
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-title: Home - CUPS 1.7.2
|_ http-robots.txt: 1 disallowed entry
|_ /
3000/tcp  closed ppp
3306/tcp  open  mysql        MySQL (unauthorized)
3500/tcp  closed rtmp-port
6697/tcp  open  irc          UnrealIRCd
8080/tcp  open  http         Jetty 8.1.7.v20120910
|_ http-title: Error 404 - Not Found
|_ http-server-header: Jetty(8.1.7.v20120910)
8181/tcp  closed intermapper
MAC Address: 00:0C:29:F8:86:FF (VMware)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (98%), Linux 3.10 - 4.11 (94%),
nated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 5.0 - 6.0.1 (Linux 3.4) (94%),
No exact OS matches for host (test conditions non-ideal).
```

6. Documentation of Findings

All vulnerabilities identified during the scanning phase were documented in a structured manner using spreadsheets and supporting screenshots as evidence. This documentation ensures traceability, repeatability, and effective communication of findings.

The following details were recorded for each vulnerability:

- Target IP address
- Open ports and protocols
- Running services and versions
- Vulnerability description
- CVE identifiers
- CVSS score and severity level
- Proof of evidence (screenshots)

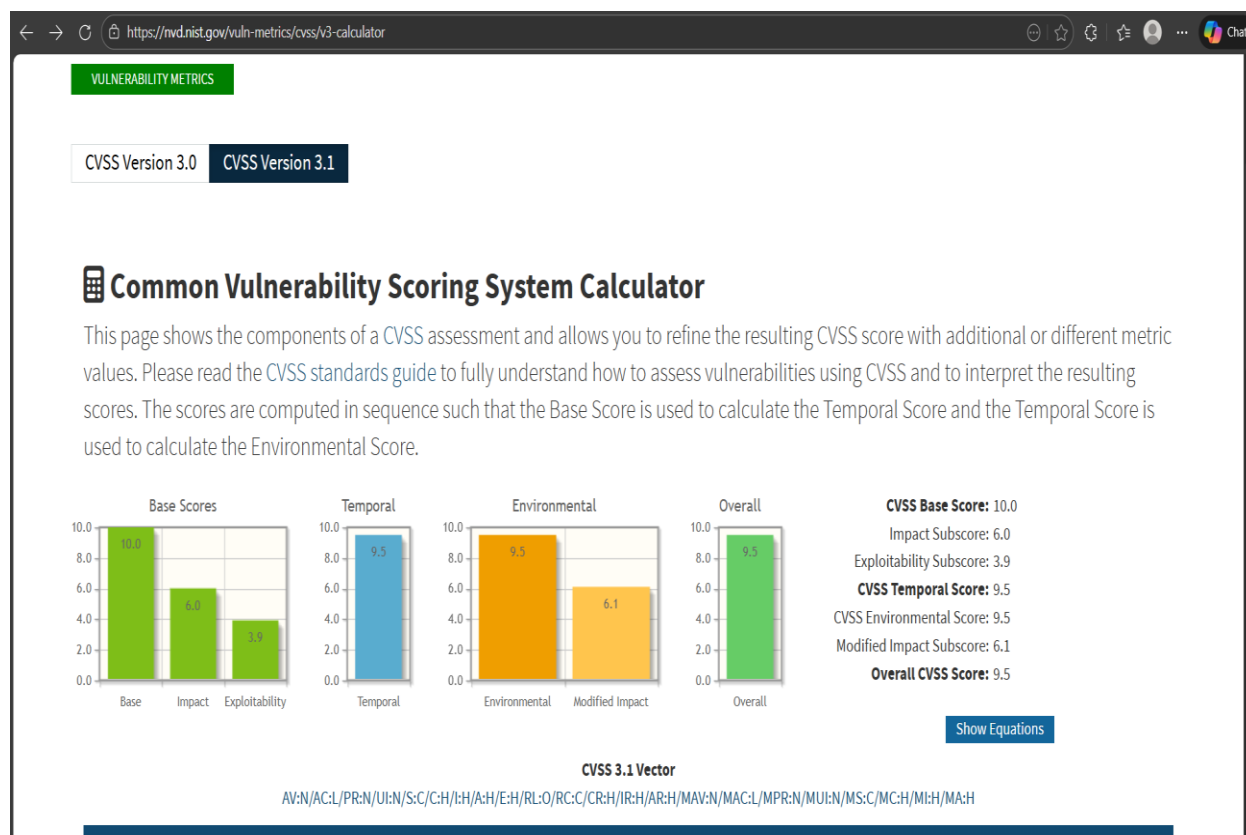
Sample Findings Table

IP Address	Port	Service	Vulnerability Description	CVSS Score	Severity
192.168.43.130	21	FTP	Outdated vsftpd service	9.8	High
192.168.43.130	22	SSH	Weak authentication exposure	6.5	Medium

7. Risk Assessment

7.1 CVSS Scoring

The Common Vulnerability Scoring System (CVSS) was used to assign severity scores to the identified vulnerabilities using the NVD CVSS Calculator.



7.2 Risk Matrix

A 3x3 risk matrix was applied to prioritize vulnerabilities based on likelihood and impact.

Vulnerability	Likelihood	Impact	Risk Level
Outdated FTP Service	High	High	High
Open SSH Service	Medium	Medium	Medium
Information Disclosure	Low	Low	Low

8. Remediation Recommendations

The following remediation steps are recommended to mitigate the identified risks:

- Update and patch all outdated services and applications
- Disable unnecessary network services and ports
- Apply strong authentication mechanisms
- Follow CIS Benchmarks for system hardening
- Regularly perform vulnerability scans

9. Discussion and Analysis

The results of the vulnerability assessment indicate that the target system is highly vulnerable due to outdated software versions and insecure default configurations. High-risk vulnerabilities identified could allow attackers to gain unauthorized access with minimal effort.

The use of automated tools such as OpenVAS significantly reduced the time required to identify vulnerabilities; however, manual verification remains essential to eliminate false positives. Risk assessment techniques such as CVSS scoring and risk matrices helped prioritize remediation efforts effectively.

10. Conclusion

The vulnerability assessment and penetration testing exercise successfully demonstrated a structured approach to identifying and analyzing security weaknesses in a controlled environment. The findings emphasize the importance of proactive security assessments and continuous monitoring. Implementing the recommended remediation steps will greatly enhance the system's security posture and resilience against attacks.

11. Appendices

Appendix A: OpenVAS Severity Levels

- Critical (9.0 – 10.0)
- High (7.0 – 8.9)
- Medium (4.0 – 6.9)
- Low (0.1 – 3.9)

Appendix B: Risk Matrix Definition

A 3x3 risk matrix was used to classify vulnerabilities based on likelihood and impact, producing Low, Medium, or High risk ratings.

12. References

The vulnerability assessment successfully identified critical security weaknesses in the test environment. Addressing these vulnerabilities will significantly improve the security posture of the system and reduce the risk of exploitation. This practical exercise demonstrates the importance of regular security assessments using structured methodologies and open-source tools.

. References

- OWASP Web Security Testing Guide
- OWASP Top 10
- NIST SP 800-115
- National Vulnerability Database (NVD)
- Kali Linux Documentation